Phase 1 Cybersecurity Architecture & Implementation Report

This report documents the defense-in-depth cybersecurity measures and full implementation of **Phase 1: Urgent Payroll Bottleneck & Payment Gateway Integration** for Edukom Group.

1. Cybersecurity Threat Model & Defense Implementations

2. Implemented Core Safeguards

Component 1: Automated NUBAN Bank Account Verification (Tutor KYC)

- **Real-time NIBSS Verification**: Using , the platform validates the 10-digit account number against the bank code in real time via NIBSS.
- **Interactive UI**: The view dynamically verifies the account holder's registered bank name as soon as 10 digits are typed.
- **Verified Recipient Registration**: Automatically calls Paystack's Transfer Recipient API to register the tutor and attach their permanent `recipient_code` (`RCP_xxxx`), eliminating manual transfer errors.
- **NDPR/PCI Masking**: Sensitive account numbers are masked (`******1234`) across UI views, logs, and spreadsheets.

Component 2: Payout Lifecycle Webhook Handlers

- `transfer.success` : Automatically updates status to `PAID` . When all items are complete, marks as `DISBURSED` .
- `transfer.failed` & `transfer.reversed` :
  - Immediately updates item status to `FAILED` .
  - Records an immutable entry in detailing the gateway rejection reason.
  - Sends an urgent email notification to Edukom management (`support@edukom.ng`).

- **Cryptographic & Idempotency Defenses**: Guarded by constant-time HMAC-SHA512 verification and duplicate detection.

Component 3: Automated Transactional Email Delivery

- **Parent Payment Receipts**:
    - Automatically dispatched via immediately upon verified payment completion.
    - Features invoice number, payment channel, transaction reference, amount paid, and description.
- **Tutor Compensation Statements (Payslips)**:
    - Dispatched via either upon successful transfer confirmation or through the one-click "*Email All Payslips*" button on the payroll run detail dashboard.
    - Includes a full tabular breakdown of each session (Date, Student, Class Level, Duration Hours, Hourly Rate, Subtotal), gross earnings, deductions, bonuses, and net payout with masked bank details.

3. Verification Suite Results

All 14 automated unit tests passed:

Test Case	Scope	Verification Focus	Result
`test_secure_reference_generation`	Payments	Cryptographic CSPRNG generation	**PASSED**
`test_hmac_signature_validation`	Payments	HMAC-SHA512 validation & tamper check	**PASSED**
`test_webhook_rejects_unauthorized_post`	Payments	Rejection of unsigned POSTs (HTTP 400)	**PASSED**
`test_replay_attack_idempotency_defense`	Payments	Replay attack duplicate drop (HTTP 200)	**PASSED**
`test_payment_receipt_email_sending`	Payments	HTML receipt formatting & email delivery	**PASSED**
`test_transfer_success_webhook_updates_status`	Payments	Status change to `PAID` & `DISBURSED`	**PASSED**
`test_transfer_failed_webhook_marks_failed`	Payments	Payout failure handling & alert logging	**PASSED**
`test_formula_injection_defense`	Payroll	CWE-1236 prefix neutralization (`=` , `@` , `+` , etc.)	**PASSED**
`test_timezone_normalization`	Payroll	Geographic timezone resolution across 5 zones	**PASSED**
`test_class_level_normalization`	Payroll	Educational keyword resolution	**PASSED**
`test_tutor_payroll_math`	Payroll	Gross, deductions, bonuses, net pay calculation	**PASSED**
`test_payslip_email_generation_and_sending`	Payroll	Itemized payslip email delivery to tutor	**PASSED**
`test_payout_failure_alert_email`	Payroll	Management alert dispatch on failed transfer	**PASSED**
`test_resolve_nuban_api_validation`	Payroll	10-digit NUBAN format validation API	**PASSED**